SEMANA 2 · MODELOS DE DESPLIEGUE E IDENTIDAD Y ACCESO

Modelos de despliegue de la nube

Parte 1 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 2 · Periodo 2026-2 · Barranquilla, Colombia

Pública, privada, comunitaria, híbrida y multi-nube: cómo decidir dónde vive cada sistema.

¿Dónde debe vivir cada sistema?

La Corporación Industrial del Caribe decide sistema por sistema, no "migra todo a la nube".

Corporación Industrial del Caribe

Manufacturera · Barranquilla

- **ERP financiero y nómina** — Datos contables y de empleados
- **Sensores y SCADA de planta** — Respuesta en milisegundos
- **Tienda B2B para distribuidores** — Picos en temporada alta
- **Analítica de demanda** — Mucho cálculo en pocas horas

?

Centro de datos propio

Nube privada on-premise

- Control total del hardware
- Inversión inicial alta (CapEx)

Nube pública

AWS, Azure, Google Cloud

- Pago por uso (OpEx)
- Elasticidad casi ilimitada

Infraestructura alojada

Nube privada alojada

- Equipos dedicados, operados
- por un tercero

Combinación

Híbrida o multi-nube

- Cada carga donde mejor encaja
- Más piezas que coordinar

Fuente: caso docente adaptado de NIST SP 800-145 — íconos AWS Architecture Icons

Cinco palabras sobre un mismo eje

Lo que cambia entre modelos es quién es dueño, quién opera y cuántos comparten la infraestructura.

HÍBRIDA: privada y pública conectadas

Ejemplo: la planta en casa y la tienda en la nube

Más control y más responsabilidad — **Más elasticidad y más compartición**



Privada on-premise

Una organización,
en su propio centro de datos

Dueño de todo



Privada alojada

Una organización, equipos
dedicados en casa de un tercero

Operación compartida



Comunitaria

Varias organizaciones
con requisitos comunes

Costo repartido

Pública

Muchos clientes sobre la
infraestructura del proveedor

Multi-tenant

+ Multi-nube: 2 o más proveedores

Fuente: adaptado de NIST SP 800-145 (modelos de despliegue) — íconos AWS Architecture Icons

Nube pública: muchos inquilinos, un hardware

Aislamiento lógico entre clientes y economías de escala del proveedor.

REGIÓN DE UN PROVEEDOR PÚBLICO · hardware compartido por miles de clientes

Cliente A
Corporación Industrial del Caribe





Red virtual aislada (VPC)
Solo ve sus propios recursos

Cliente B
Un banco regional





Red virtual aislada (VPC)
Solo ve sus propios recursos

Cliente C
Una clínica





Red virtual aislada (VPC)
Solo ve sus propios recursos

Capa de virtualización: el hipervisor reparte el hardware y aísla cada VM
(en AWS, el sistema Nitro)



Servidores, redes y almacenamiento físicos del proveedor
Amortizados entre miles de clientes: menor costo por unidad de cómputo

El cliente nunca ve ni toca el hardware físico

Elasticidad

Pides más capacidad en minutos y la sueltas cuando termina el pico

Pago por uso

Sin inversión inicial: gasto operativo (OpEx) mensual

Multi-tenant

Muchos inquilinos comparten hardware con aislamiento lógico

Fuente: adaptado de NIST SP 800-145 y AWS Nitro System — íconos AWS Architecture Icons

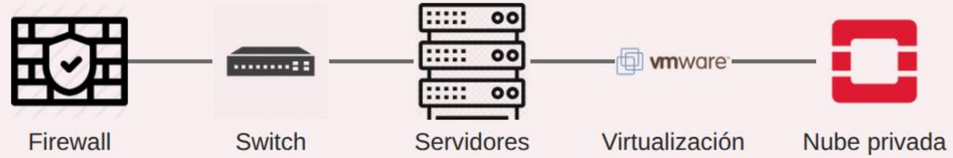
Nube privada: una sola organización

Dedicada y de un único inquilino; cambia quién pone el edificio y quién opera.

ON-PREMISE: en tus instalaciones

Planta de Barranquilla · equipo de TI propio

Centro de datos propio



Energía, enfriamiento, seguridad física y personal: todo es tuyo



Usuarios y planta

red interna / VPN

ALOJADA: en casa de un tercero

Proveedor de hosting o colocation · equipo dedicado

Centro de datos del proveedor



Contrato (SLA)

El proveedor opera: energía, enfriamiento, seguridad física

Equipos solo de tu organización (single-tenant)



Oficinas de CIC

enlace privado o VPN

Dimensión	On-premise	Alojada
Hardware	Propio (CapEx)	Arrendado o dedicado
Operación	Tu equipo de TI	El proveedor, bajo contrato
Ubicación	Tus instalaciones	Instalaciones del proveedor

Fuente: adaptado de NIST SP 800-145 y OpenStack Docs (CC BY 3.0)

¿Quién gestiona qué en cada modelo?

Mientras más a la derecha, más capas delega la empresa en el proveedor.

	Privada on-premise	Privada alojada	Pública (IaaS)
Instalaciones físicas	Tu organización	El proveedor	El proveedor
Red y almacenamiento	Tu organización	El proveedor	El proveedor
Servidores	Tu organización	El proveedor	El proveedor
Virtualización	Tu organización	Según contrato	El proveedor
Sistema operativo	Tu organización	Tu organización	Tu organización
Aplicaciones	Tu organización	Tu organización	Tu organización
Datos y accesos	Tu organización	Tu organización	Tu organización



Regla de oro

Los datos y los accesos son siempre tuyos, sin importar el modelo.

En la pública esto se llama modelo de responsabilidad compartida.

Fuente: adaptado de AWS Shared Responsibility Model y NIST SP 800-145

Nube comunitaria: requisitos compartidos

Varias organizaciones con la misma misión o normativa reparten una infraestructura común.



Ejemplo real

AWS GovCloud (US): regiones aisladas para cargas de entidades del gobierno de Estados Unidos, con requisitos de cumplimiento propios.

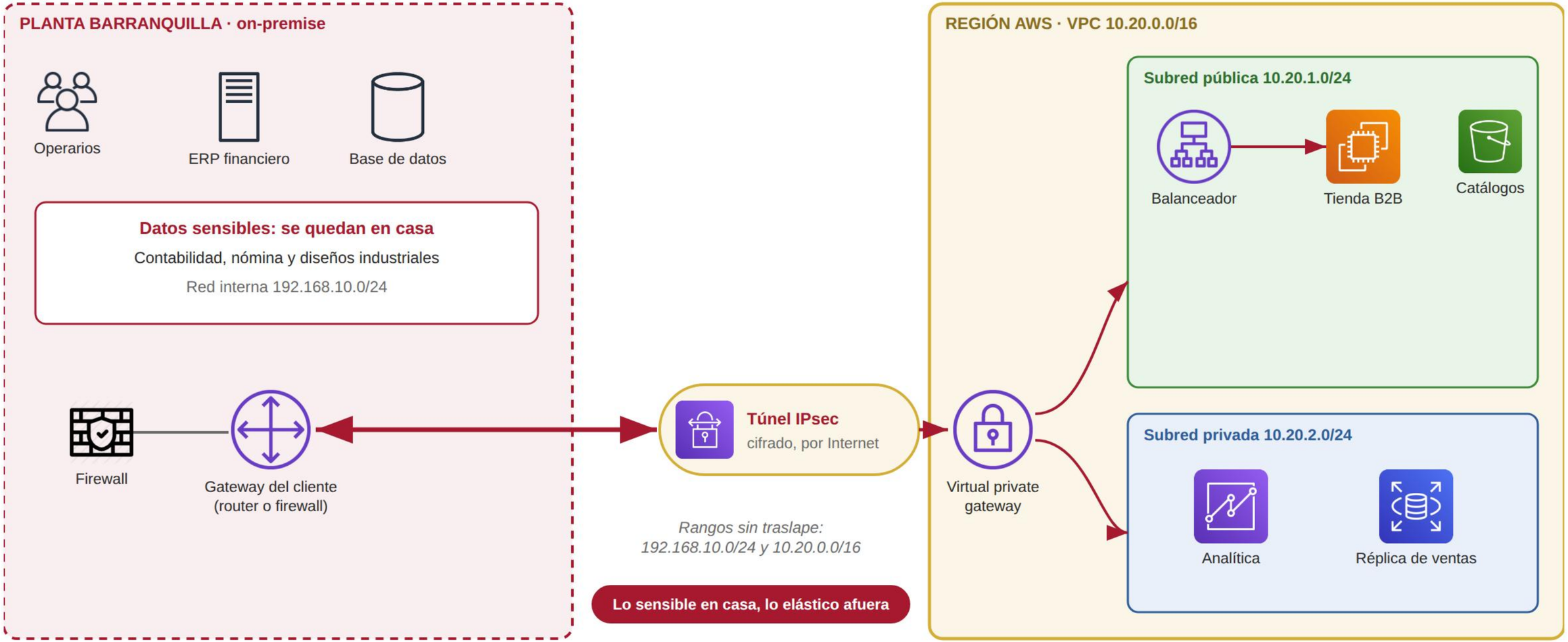
Ejemplo ilustrativo

Un consorcio de universidades del Caribe comparte un clúster de cómputo científico: reparten el costo y aplican las mismas reglas de datos de investigación.

Fuente: adaptado de NIST SP 800-145 y documentación de AWS GovCloud (US)

Nube híbrida: dos mundos, un túnel

La empresa conserva su centro de datos y extiende la red hacia una VPC en la nube.



Fuente: adaptado de AWS Site-to-Site VPN y AWS Architecture Center — íconos AWS Architecture Icons

Cuatro patrones de uso de la híbrida

Desborde, recuperación, borde y migración gradual: cuatro razones reales para conectar ambos mundos.

1 · Desborde de picos (cloud bursting)



La nube absorbe el exceso y se apaga al terminar la temporada

Pagas solo las horas de pico

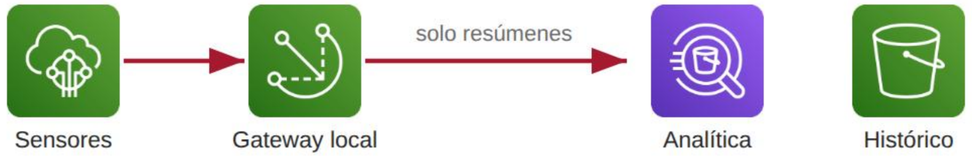
2 · Respaldo y recuperación en la nube



Si la planta falla, la nube retoma el servicio

Sin comprar un segundo centro de datos

3 · Borde: procesar cerca de la planta



La decisión en milisegundos ocurre en la planta

La nube guarda y analiza el histórico

4 · Migración por fases



La híbrida también es un camino, no solo un destino

Se migra primero lo que menos riesgo tiene

Fuente: adaptado de AWS Prescriptive Guidance y AWS Architecture Center — íconos AWS Architecture Icons

MULTI-NUBE

Multi-nube: cada carga donde mejor encaja

Dos o más proveedores públicos a la vez, coordinados con identidad, red y código comunes.

AWS

Tienda B2B y datos operativos



Servidores web



Base de datos

Carga elegida por su mejor encaje

Microsoft Azure

Correo, Office e identidad



Entra ID



Windows Server

Carga elegida por su mejor encaje

Google Cloud

Analítica de demanda



BigQuery



Cloud Storage

Carga elegida por su mejor encaje

Lo común entre nubes: identidad única · enlaces de red · infraestructura como código (Terraform) · monitoreo

Todo lo que no es propietario del proveedor es lo que permite coordinar varias nubes

Por qué usar varias nubes

- Cada carga en el servicio que mejor la resuelve
- Resiliencia: no depender de un solo proveedor
- Requisitos regulatorios o de ubicación de datos
- Herencia de fusiones y adquisiciones

Lo que cuesta

- Equipos que dominen dos o más consolas
- Cobros por salida de datos entre nubes
- Seguridad y gobierno duplicados
- Menor aprovechamiento de descuentos por volumen

Fuente: adaptado de Azure Architecture Center (CC BY 4.0) y AWS Architecture Center — íconos AWS, Azure y Google Cloud

CONCEPTOS CLAVE

Híbrida no es lo mismo que multi-nube

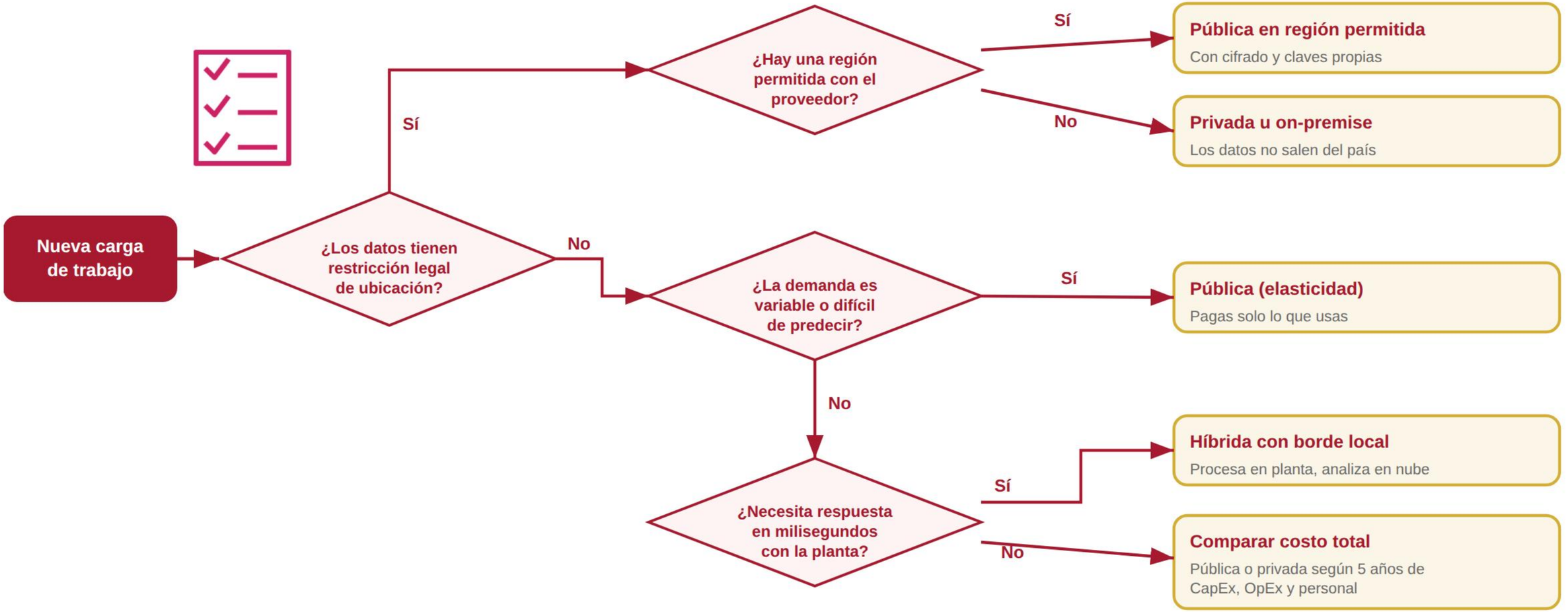
Se distinguen por dos preguntas: ¿hay infraestructura propia? ¿cuántos proveedores públicos hay?

¿Incluye infraestructura propia? \ ¿Cuántos proveedores públicos se usan?	Uno	Dos o más
No	**Solo nube pública** Todo en un proveedor • Un contrato, una consola • Operación más simple • Lock-in más alto	**Multi-nube** Varios proveedores, sin centro de datos propio • Mejor servicio por carga • Mayor complejidad • Menor dependencia de uno solo
Sí	**Híbrida** Centro de datos propio + un proveedor • Datos sensibles en casa • Tienda y analítica en AWS CIC hoy (plan)	**Híbrida y multi-nube** Centro de datos propio + varios proveedores • Se suma Azure por Entra ID • Se suma Google por BigQuery CIC en 2 o 3 años

Fuente: elaboración propia a partir de NIST SP 800-145 y Azure Architecture Center (CC BY 4.0)

Cómo decidir: cuatro preguntas en orden

Ubicación legal, variabilidad de la demanda, latencia y costo total llevan al modelo.



Fuente: elaboración propia a partir de AWS Well-Architected y NIST SP 800-145

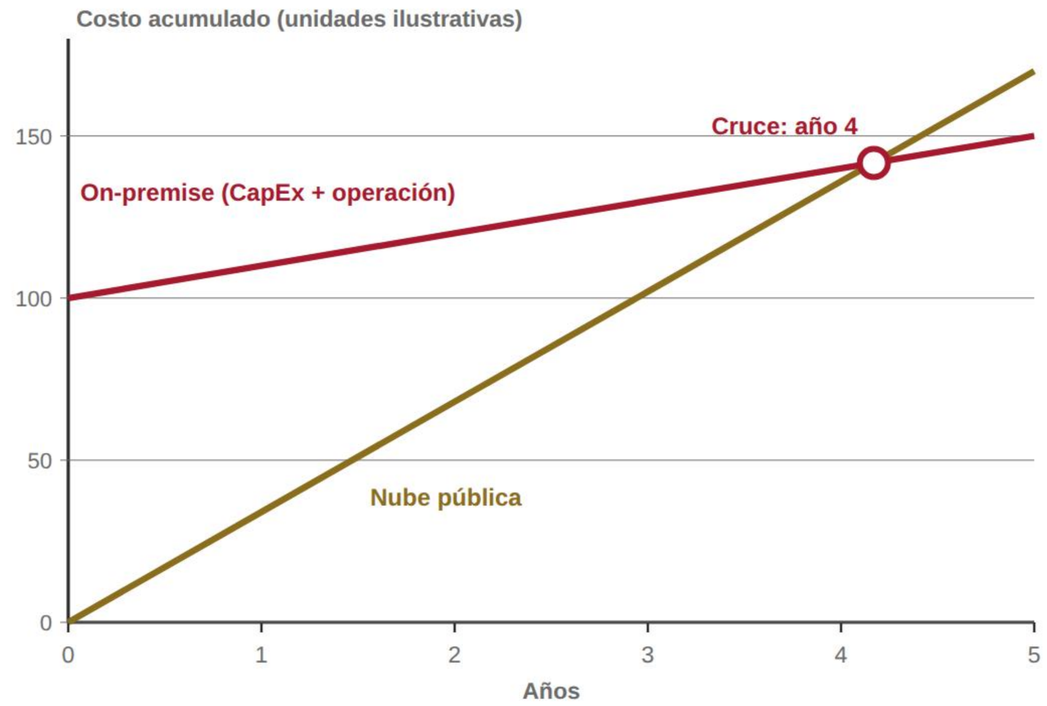
COSTOS

CapEx contra OpEx: depende del perfil de uso

Los números son ilustrativos; lo importante es la forma de las curvas y su cruce.

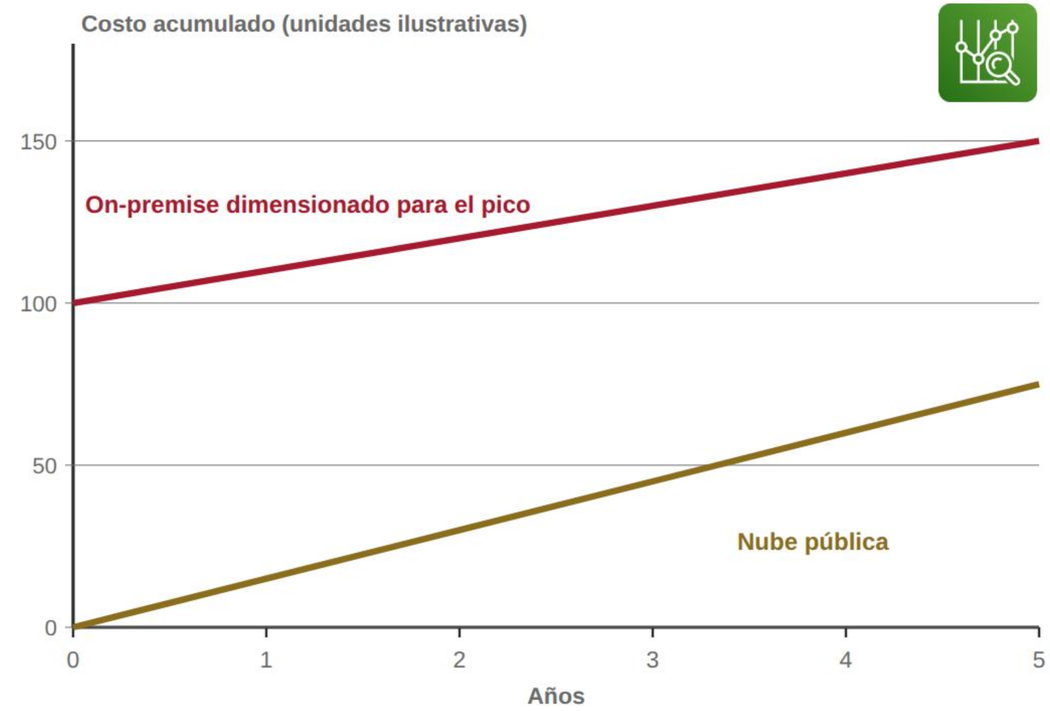
Carga estable 24 x 7, uso alto

El centro de datos propio termina siendo más barato



Carga con picos, uso medio bajo

La nube cobra solo lo usado; on-premise se dimensiona para el pico



Costos que se olvidan al comparar:

energía y enfriamiento · personal de TI · renovación de hardware cada 4 o 5 años · licencias · en la nube, salida de datos y soporte

Fuente: modelo ilustrativo propio; conceptos de AWS Well-Architected (Cost Optimization)

Soberanía de datos y casos colombianos

Dónde viven los datos importa tanto como quién los opera.

Tres sectores, tres presiones

Banca

La Superintendencia Financiera vigila el riesgo de terceros y de computación en la nube

Prioridad: continuidad y control

Salud

Historias clínicas: datos personales sensibles bajo la Ley 1581 de 2012

Prioridad: confidencialidad

Estado

Contratación de nube pública mediante acuerdos marco de Colombia Compra Eficiente

Prioridad: contratación transparente

¿Qué pasa si el dato sale de Colombia?



Ley 1581 de 2012: exige nivel adecuado de protección o autorización del titular

Qué hacer antes de elegir región

1. Clasificar los datos por sensibilidad
2. Revisar contrato y cláusulas del proveedor
3. Elegir región y registrar la decisión
4. Cifrar con claves propias (KMS)

La soberanía de datos es un requisito de diseño, no un detalle del contrato

Fuente: Ley 1581 de 2012 (Colombia); documentación de regiones de AWS — íconos AWS Architecture Icons

CIERRE

Lo que queda de la Parte 1

La respuesta para CIC es híbrida: cada sistema en el modelo que mejor lo sirve.

ERP financiero y nómina Datos sensibles y ley de datos	**Privada on-premise**
Sensores y SCADA Latencia de milisegundos	**On-premise con borde local**
Tienda B2B Picos de temporada	**Pública en AWS**
Analítica de demanda Cálculo por ráfagas	**Pública (AWS o Google)**

Resultado para CIC



Híbrida

planta en casa
nube para lo elástico
+ posible multi-nube
más adelante

Una VPN conecta ambos lados; la identidad se unifica en la Parte 3

Tres ideas para llevar

- **Cinco modelos sobre un eje de control y compartición**
- **Se decide por carga de trabajo, no por moda**
- **Siguiente: cómo se construye una nube privada por dentro**

Fuente: elaboración propia — caso docente Corporación Industrial del Caribe

ENCUADRE

Una nube privada también ofrece autoservicio

La plataforma convierte un pool de hardware en recursos pedidos por API.

USUARIOS · autoservicio por portal o API



Desarrolladores



Portal web



CLI y API REST

Piden una máquina virtual, una red o un disco y la reciben en minutos

Sin abrir un ticket al área de TI

PLATAFORMA DE NUBE PRIVADA · OpenStack



Identidad



Cómputo



Redes



Bloques

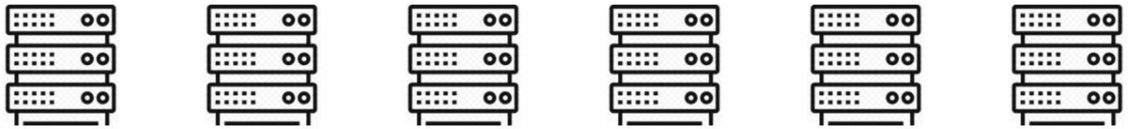


Objetos



Imágenes

POOL DE HARDWARE · servidores, discos y switches de la planta





Switches



Almacenamiento

Sin esta capa solo hay virtualización, no una nube

Fuente: adaptado de OpenStack Docs (CC BY 3.0) y NIST SP 800-145 — íconos del proyecto OpenStack

Mapa de servicios de OpenStack

Cada servicio hace una cosa, tiene su API y se coordina por base de datos y cola.



Horizon



Usuarios

Portal web, CLI o llamadas REST

cada petición lleva un token



Keystone · identidad y catálogo

usuarios, proyectos, roles, tokens y lista de endpoints



Nova

Máquinas virtuales y su ciclo de vida



Neutron

Redes, routers, IP flotantes, firewalls



Glance

Imágenes de sistema operativo



Cinder

Discos en bloques para las VM



Swift

Objetos con réplicas vía REST



Base de datos compartida (MariaDB o MySQL): metadatos



Cola de mensajes (RabbitMQ): comunicación entre servicios

Nodos físicos





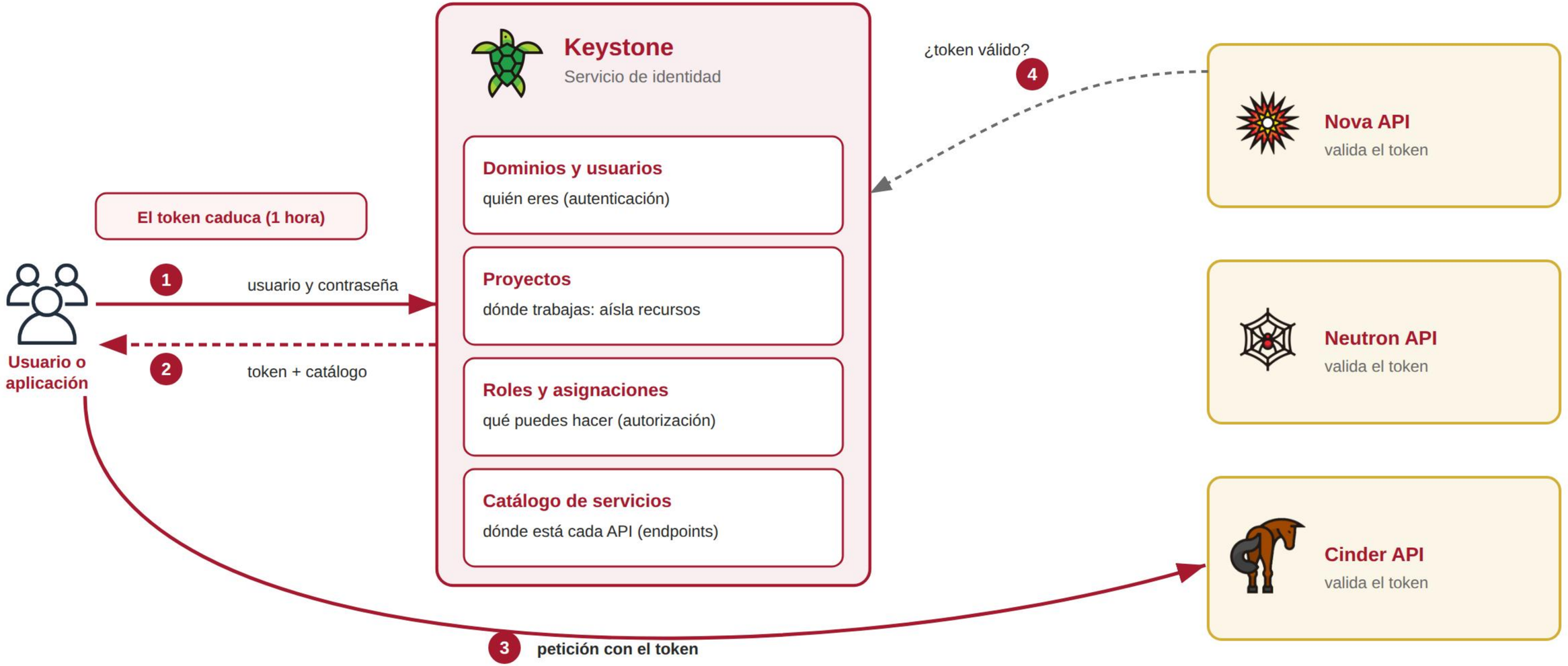


Controladores y nodos de cómputo con hipervisor KVM
Nodos de almacenamiento (Swift, Ceph o discos locales)
Red de gestión separada de la red de las VM

Fuente: adaptado de OpenStack Docs (CC BY 3.0) — OpenStack Conceptual Architecture

Keystone: quién eres y a dónde puedes ir

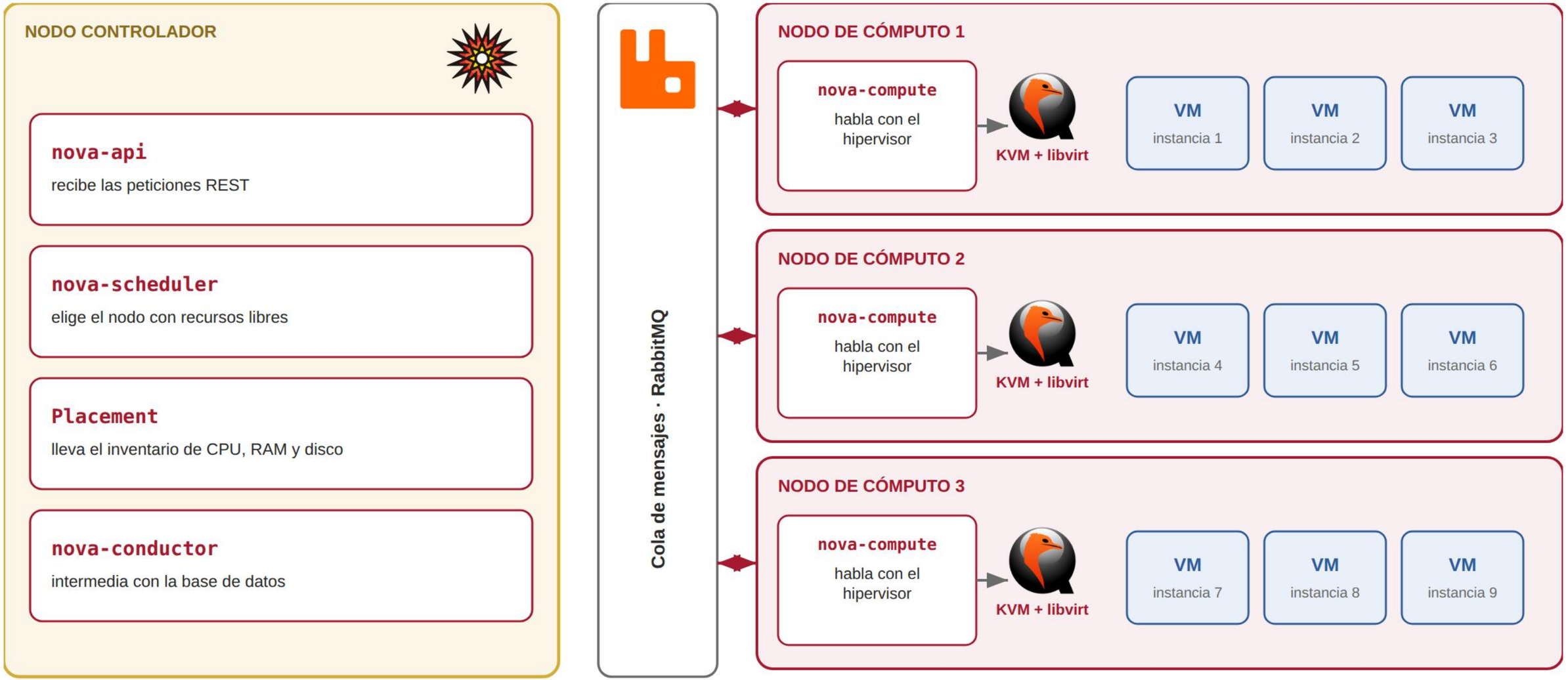
Todo servicio de OpenStack confía en un único proveedor de identidad.



Fuente: adaptado de OpenStack Docs (Keystone, CC BY 3.0) — íconos del proyecto OpenStack

Nova: el cerebro del cómputo

Un controlador decide y coordina; los nodos de cómputo ejecutan las máquinas virtuales.



Fuente: adaptado de OpenStack Docs (Nova architecture, CC BY 3.0)

SEMANA 2 · MODELOS DE DESPLIEGUE E IDENTIDAD Y ACCESO

Nube privada, conexiones e identidad

Parte 2 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

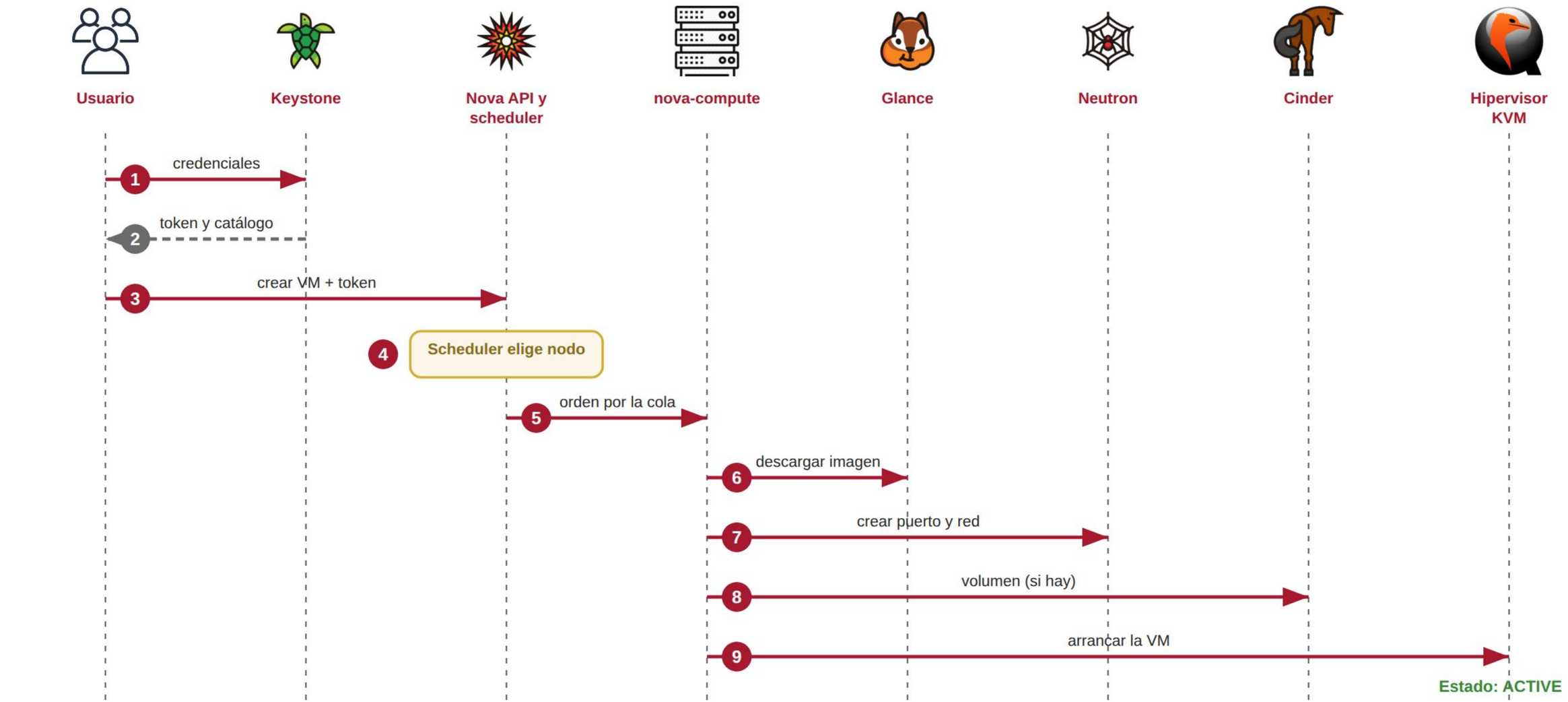
Semana 2 · Periodo 2026-2 · Barranquilla, Colombia

OpenStack, túneles y enlaces dedicados, lock-in, y los fundamentos de autenticación y autorización

FLUJO

Lanzar una VM paso a paso

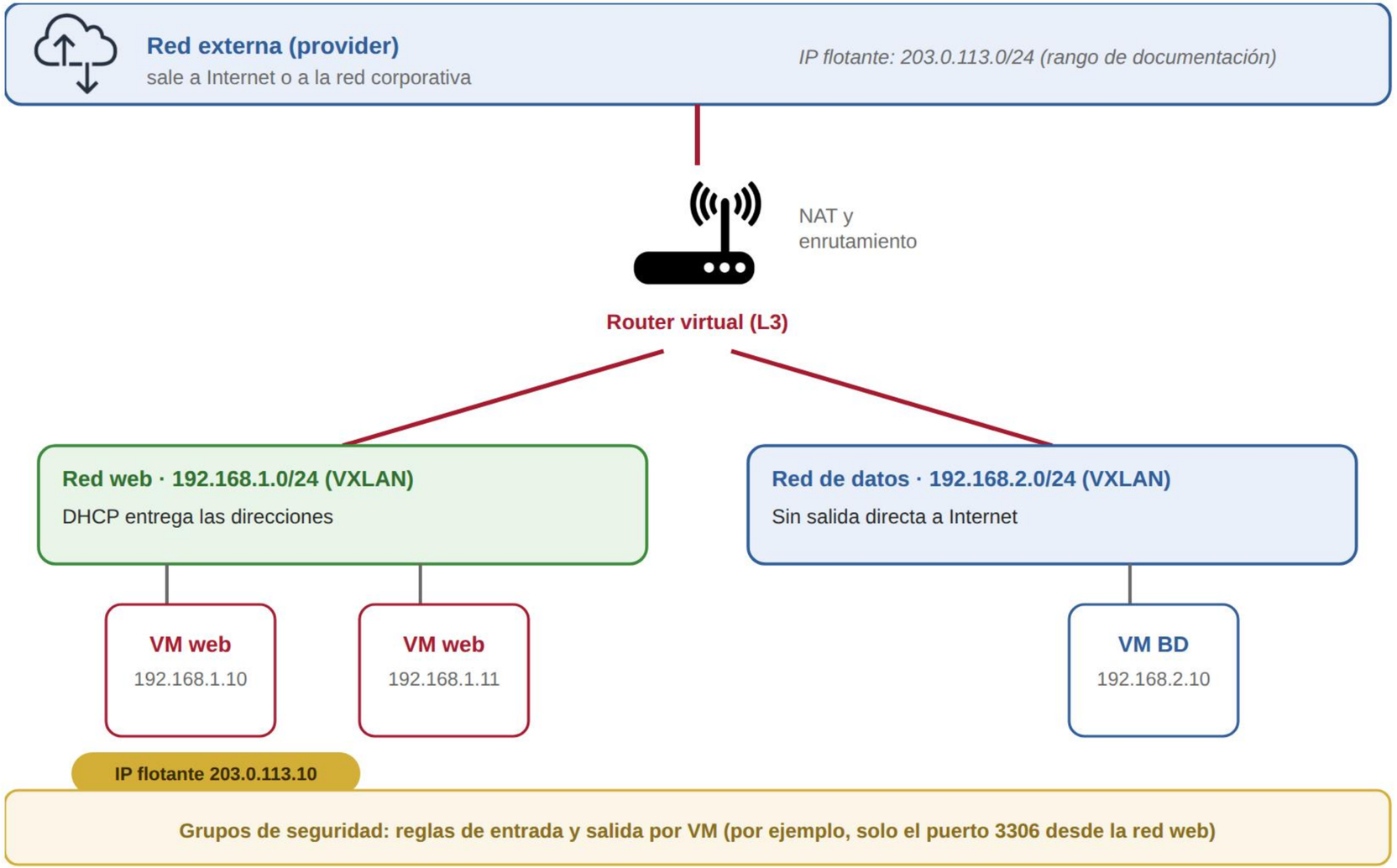
Cada servicio aporta una pieza: identidad, decisión, imagen, red, disco y arranque.



Fuente: adaptado de OpenStack Docs (Nova: Launch an instance, CC BY 3.0)

Neutron: la red virtual de cada proyecto

Routers, subredes, IP flotantes y grupos de seguridad definidos por software.



Neutron

Redes como servicio

Redes de proyecto

VXLAN: cada equipo, su red aislada

Redes provider

VLAN o planas: salen al mundo real

Routers e IP flotantes

NAT hacia la red externa

Plugin ML2 con OVS u OVN

conmutación virtual en cada nodo

Fuente: adaptado de OpenStack Docs (Networking guide, CC BY 3.0)

Glance, Cinder y Swift: imágenes, bloques y objetos

Tres formas de guardar datos, con usos distintos dentro de la misma nube.

Glance

Catálogo de imágenes

Ubuntu · Windows · CentOS

Plantillas de disco (qcow2, raw) que sirven para arrancar VM

Se guardan en Swift o Ceph

Instancia (VM)

Disco de arranque

Volumen de datos

Cinder

Almacenamiento en bloques

Volumen 1 · Volumen 2 · Instantánea

Un volumen sobrevive a la VM, se adjunta y se desadjunta

Respaldado por LVM, Ceph o SAN

Swift

Almacenamiento de objetos

Cliente (HTTP / REST)

Proxy

Nodo · zona 1 · Nodo · zona 2 · Nodo · zona 3

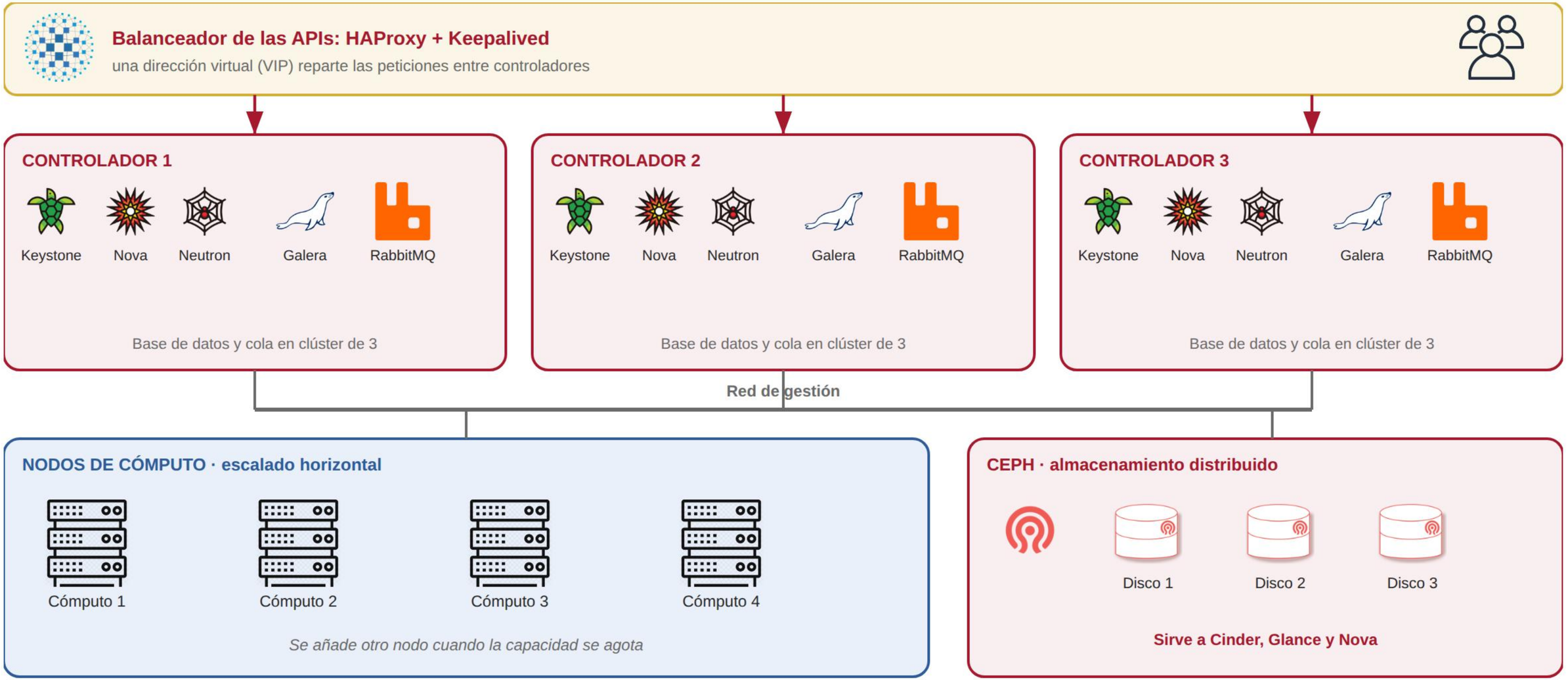
Cada objeto se guarda en 3 réplicas repartidas en zonas distintas; no es un disco, se accede por URL

Fuente: adaptado de OpenStack Docs (Cinder, Swift y Glance, CC BY 3.0)

PRODUCCIÓN

Una nube privada lista para producción

Tres controladores, clústeres de base de datos y cola, nodos de cómputo y Ceph.



Fuente: adaptado de OpenStack Docs (High Availability Guide, CC BY 3.0) — íconos OpenStack y Ceph

MicroStack: OpenStack en un solo nodo

Una instalación ligera para aprender con la misma API que la de producción.

UN SOLO NODO · portátil, mini PC o servidor





Keystone



Horizon



Nova



Neutron



Glance



Cinder

Empaquetado por Canonical y desplegado con snap

1. **Instalar** el paquete snap en Ubuntu
2. **Inicializar** el nodo: red, almacenamiento y servicios
3. **Abrir Horizon** y entrar con el usuario administrador
4. **Lanzar una VM** con la imagen de prueba (por ejemplo, CirrOS)

Para qué sirve

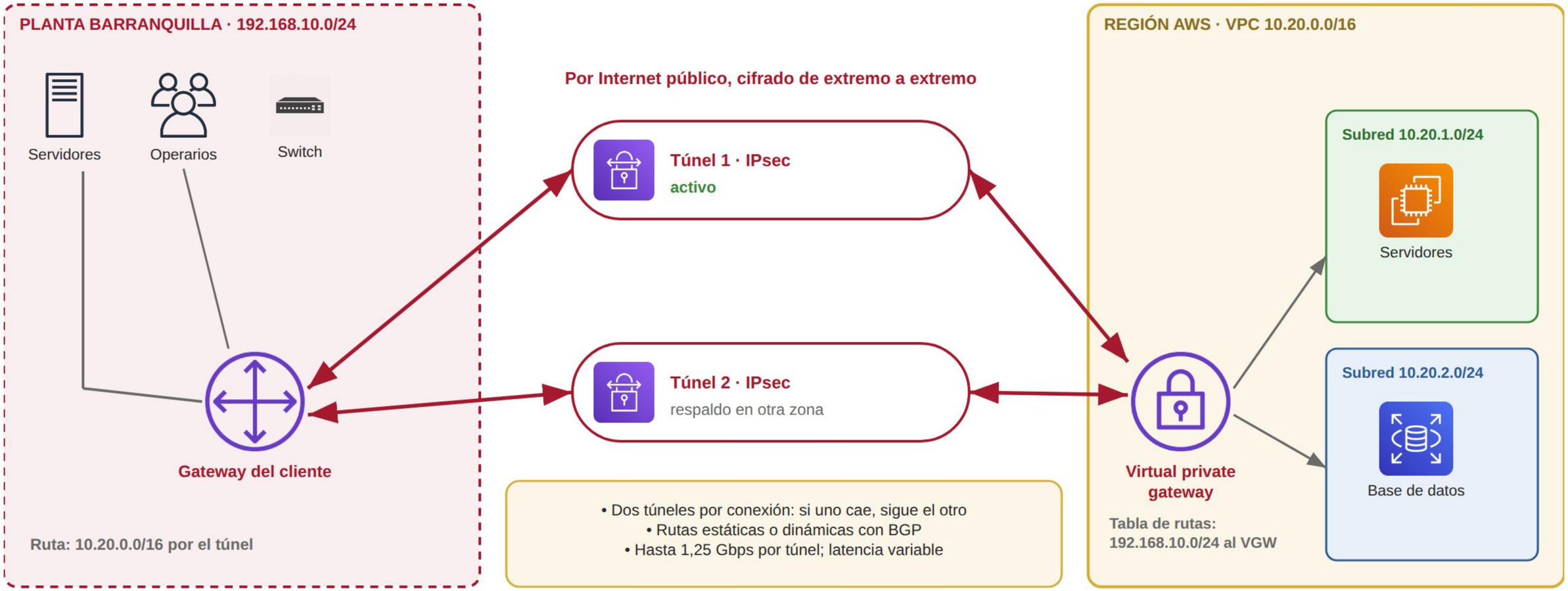
Laboratorios, pruebas de concepto y aprendizaje: la API es la misma que en producción.

Para qué no: cargas críticas. Ahí se usa un despliegue multinodo con alta disponibilidad.

Fuente: adaptado de documentación de Canonical (MicroStack) y OpenStack Docs (CC BY 3.0)

VPN sitio a sitio: un túnel cifrado por Internet

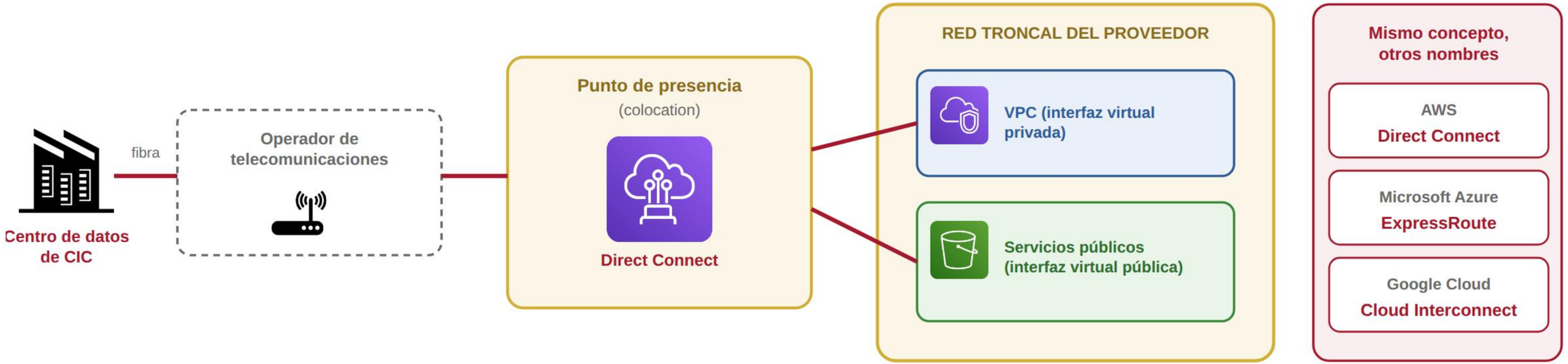
La opción más rápida y económica para conectar la planta con la nube.



Fuente: adaptado de AWS Site-to-Site VPN User Guide — íconos AWS Architecture Icons

Enlace dedicado: una fibra privada hasta la nube

Más estable y con más ancho de banda que la VPN, a cambio de tiempo y presupuesto.



Latencia predecible

sin salir a Internet público

Hasta 100 Gbps

según el puerto contratado

Semanas de instalación

contrato con el operador

Sin cifrado por defecto

se añade MACsec o VPN encima

Fuente: adaptado de AWS Direct Connect User Guide, Azure ExpressRoute y Google Cloud Interconnect — íconos AWS Architecture Icons

DEPENDENCIA DE PROVEEDOR

Vendor lock-in: tres niveles de atadura

Mientras más arriba en la pila usas servicios propietarios, más caro es irse.

Costo de salir de un proveedor (ilustrativo)

1 · Infraestructura

Máquinas virtuales, redes y discos estándar

Lock-in bajo

2 · Datos

Volumen acumulado y formatos propietarios; cargos por salida

Lock-in medio

3 · Aplicación

Servicios gestionados con APIs propietarias

Lock-in alto

¿Por qué atrapa?

- Cada API propietaria que usas es una dependencia
- Mover datos cuesta tiempo y dinero
- Los equipos aprenden un solo ecosistema

No siempre es malo

- Los servicios gestionados ahorran operación
- Lo importante es elegirlo con conciencia
- Y tener un plan de salida documentado



Fuente: adaptado de AWS Well-Architected y Azure Architecture Center (CC BY 4.0)

Estrategias para no quedar atrapado

Contenedores, código de infraestructura, datos abiertos e identidad estándar.

	Opción portable	Opción propietaria
Cómputo	Contenedores y Kubernetes	Funciones o plataformas propietarias
Infraestructura	Código declarativo (Terraform)	Plantillas propias de cada nube
Datos	PostgreSQL, MySQL, Parquet	Bases NoSQL propietarias
Identidad	Federación estándar (SAML y OIDC)	Directorio exclusivo de un proveedor
Observabilidad	Prometheus y Grafana	Monitoreo cerrado

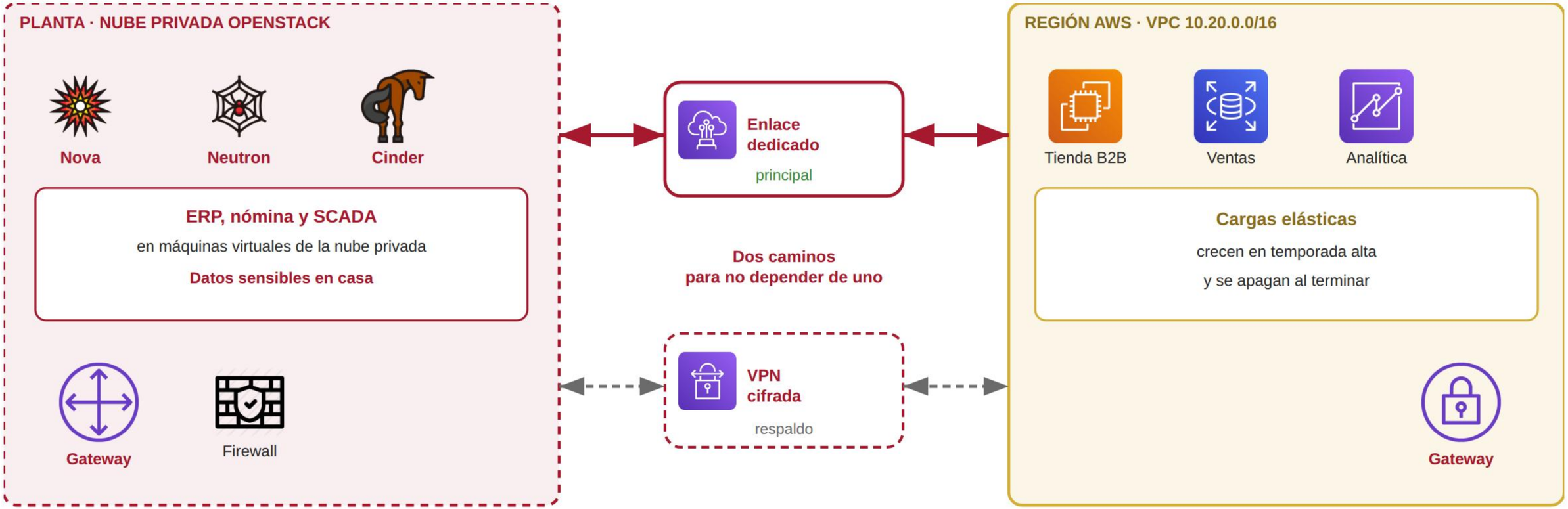
Regla práctica: la portabilidad tiene costo; aplícala donde el riesgo lo justifique y documenta la ruta de salida

Fuente: adaptado de AWS Prescriptive Guidance y Azure Architecture Center (CC BY 4.0)

CIERRE

Lo que queda de la Parte 2

La planta y la nube se conectan por dos caminos para no depender de uno solo.



Tres ideas para llevar

- OpenStack ofrece los servicios de una nube
- VPN para empezar, enlace dedicado para exigir
- Portabilidad por capas y plan de salida

Fuente: elaboración propia a partir de OpenStack Docs y AWS Architecture Center — caso docente CIC

ENCUADRE

Tres tipos de identidad llaman a la nube

Personas, aplicaciones y clientes externos: cada una se gestiona distinto.

IDENTIDADES (quién llama)

Personas de la plantilla
Empleados, ingenieros, auditores

Aplicaciones y máquinas
Servidores, funciones, pipelines

Clientes externos
Distribuidores que usan la tienda B2B

Directorio corporativo y SSO

Roles con credenciales temporales

Grupo de usuarios de la aplicación

Una identidad es cualquier persona, programa o máquina que pide algo a la nube

API de la nube

cada llamada se autentica y se autoriza

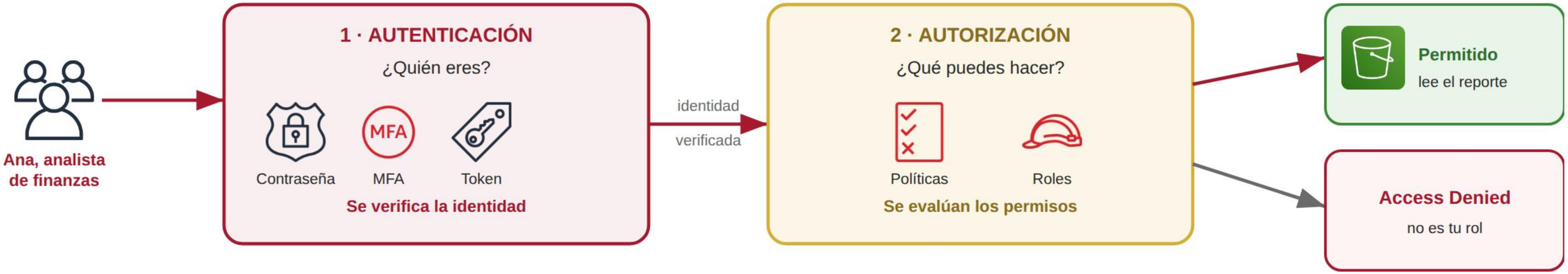
Datos · Cómputo · Bases

El perímetro ya no es la red es la identidad de quien llama

Fuente: adaptado de AWS IAM User Guide y Microsoft Entra documentation — íconos AWS Architecture Icons

Autenticación y autorización no son lo mismo

Primero se verifica quién eres; después se decide qué puedes hacer.



Analogía: el edificio de la planta

En la portería muestras el carnet con tu foto:
eso es autenticarse.

El carnet abre solo el piso 3 y la sala de reuniones:
eso es autorizarse.

Error frecuente

Entrar correctamente NO significa
tener permiso para todo

Puedes estar dentro y aun así
recibir "Access Denied": es normal

y es la forma en que el sistema te protege

Fuente: adaptado de AWS IAM User Guide y NIST SP 800-63 — íconos AWS Architecture Icons

Tres factores y la idea de MFA

Un atacante tendría que vulnerar dos categorías distintas, no una.

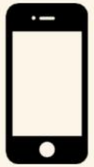


Algo que sabes

Contraseña, PIN, frase secreta

Riesgo

Se puede adivinar, filtrar o robar por phishing



Algo que tienes

Celular con app autenticadora, llave FIDO2, token físico

Riesgo

Se puede perder, pero no se copia a distancia



Algo que eres

Huella digital, rostro

Riesgo

Difícil de falsificar, pero no se puede cambiar

MFA = dos o más factores de categorías distintas

Contraseña (sabes) + **Código del celular (tienes)** = **Acceso más seguro**

Dos contraseñas distintas NO son MFA: son dos veces el mismo factor

Fuente: adaptado de NIST SP 800-63B y AWS IAM User Guide (MFA)

MFA en la práctica: del inicio de sesión a la llave

No todos los segundos factores protegen igual contra el phishing.

Inicio de sesión con MFA

1.  **Ana ingresa usuario y contraseña**
2.  **La consola pide un código**
3.  **Ana abre su app autenticadora**
4.  **Escribe el código de 6 dígitos (cambia cada 30 s)**
5.  **Acceso concedido a la sesión**

Fortaleza del segundo factor

Solo contraseña

Insuficiente

SMS al celular

Débil: SIM swap

App autenticadora (TOTP)

Buena

Llave de seguridad FIDO2 o passkey

Resiste el phishing

Fuente: adaptado de AWS IAM User Guide (MFA) y FIDO Alliance

El usuario raíz: la llave maestra

Nace con la cuenta, lo puede todo y casi nunca debería usarse.

CUENTA AWS DE LA CORPORACIÓN INDUSTRIAL DEL CARIBE



El uso diario debe hacerse con usuarios y roles, no con la raíz

(es el cuarto de máquinas con la llave maestra)

Tareas que solo la raíz puede hacer

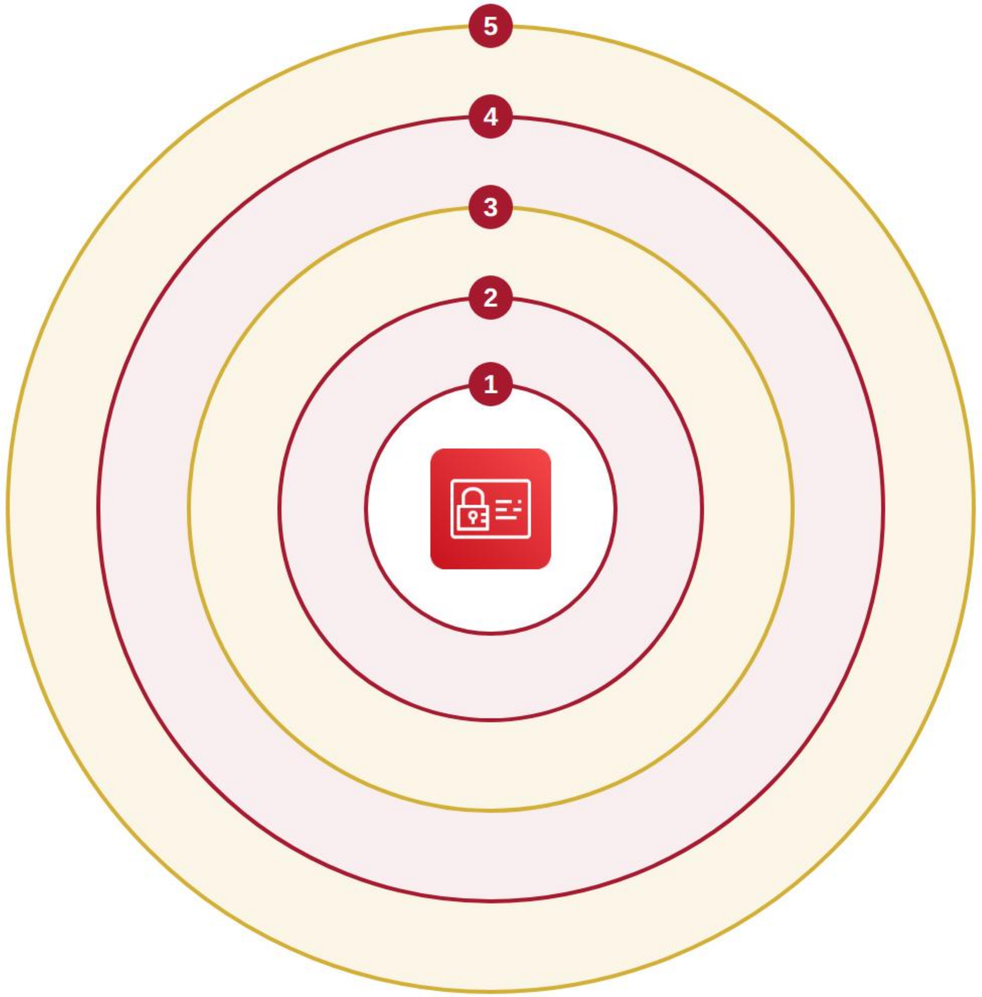
1. **Cerrar la cuenta**
2. **Cambiar el plan de soporte**
3. **Restaurar permisos de IAM si se bloqueó el administrador**
4. **Cambiar el nombre, correo o contraseña de la cuenta**

Para todo lo demás: un usuario administrador

Fuente: adaptado de AWS IAM User Guide (Root user best practices) — íconos AWS Architecture Icons

Cinco capas para blindar la raíz

Cada capa añade una barrera; juntas hacen casi inviable un acceso indebido.



1 — MFA con llave de seguridad física

Idealmente dos llaves guardadas en sitios distintos

2 — Sin claves de acceso programáticas

Ninguna llave de API para la raíz: nunca

3 — Correo de grupo corporativo

Por ejemplo aws-raiz@ de la empresa, con varios responsables

4 — Contraseña larga y única

Guardada en una caja fuerte con acceso dual

5 — Alerta si alguien la usa

Evento de inicio de sesión raíz → aviso inmediato

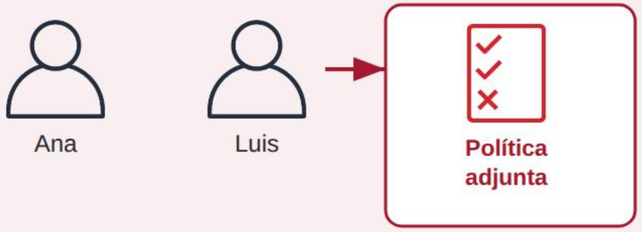
Fuente: adaptado de AWS IAM User Guide (Root user best practices) y AWS Well-Architected (Security)

Usuarios, grupos y roles en IAM

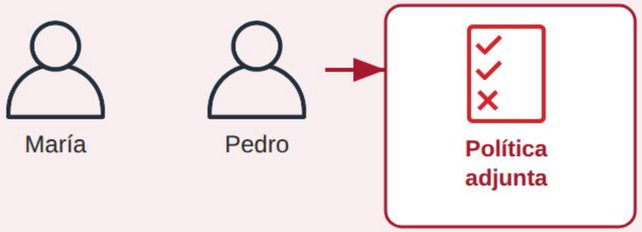
Los permisos se dan a grupos y roles; las personas entran y salen.

CUENTA AWS · IAM

Grupo Finanzas



Grupo Desarrollo



Usuario IAM

Una identidad permanente

con credenciales de largo plazo

Úsalo solo si no hay federación posible

Grupo

Una colección de usuarios

que comparten permisos

Al cambiar de área, Ana pasa de grupo y listo

Un usuario puede pertenecer a varios grupos

ROLES · identidad sin credenciales fijas

Rol asumido por:

Una instancia EC2

la app lee de S3

permisos temporales mientras dura la sesión

Rol asumido por:

Un empleado federado

entra con el directorio

permisos temporales mientras dura la sesión

Rol asumido por:

Otra cuenta de AWS

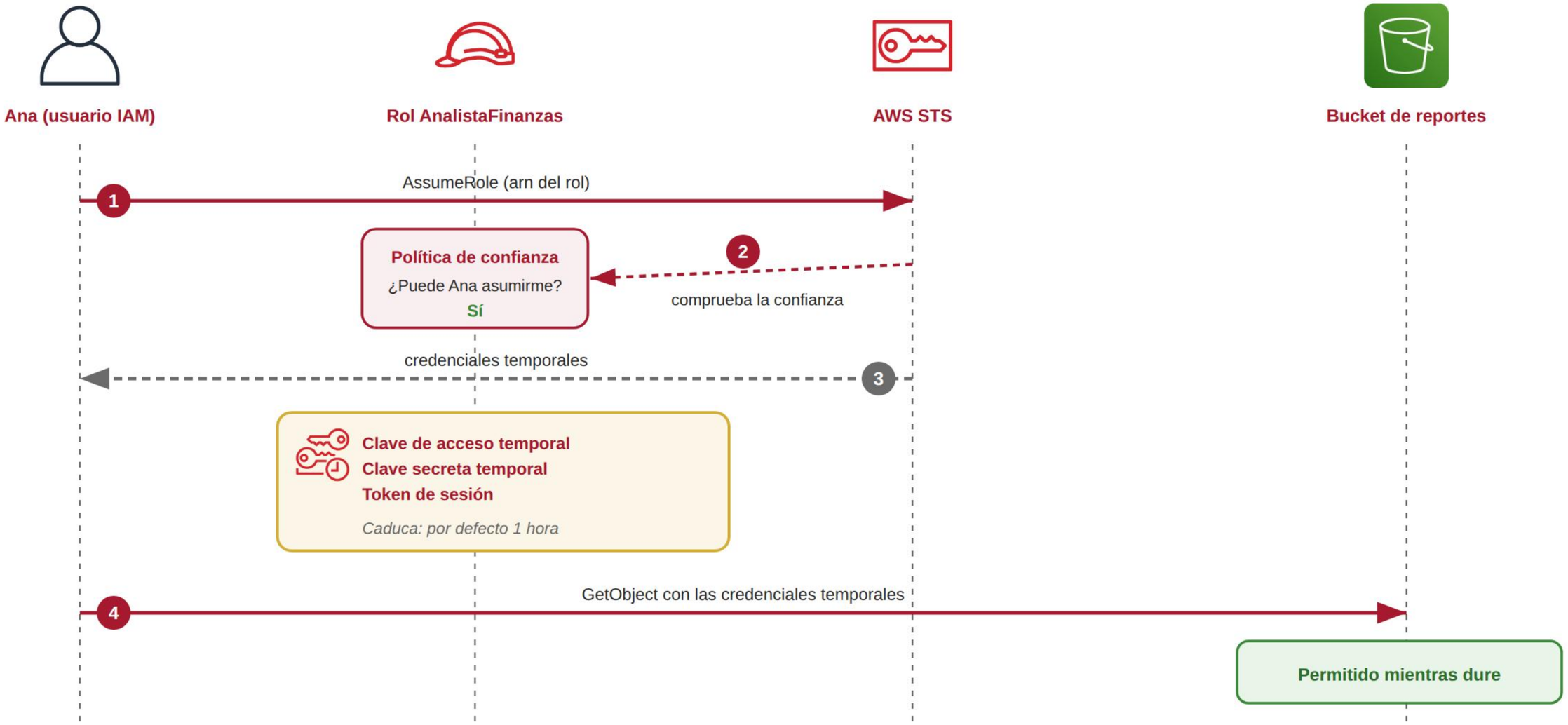
la de auditoría externa

permisos temporales mientras dura la sesión

Fuente: adaptado de AWS IAM User Guide — íconos AWS Architecture Icons

AssumeRole: el rol por dentro

El rol entrega credenciales temporales tras comprobar la confianza.



Fuente: adaptado de AWS IAM User Guide (Temporary security credentials) y AWS STS — íconos AWS Architecture Icons

Largo plazo contra temporales

Una credencial que caduca limita el daño de cualquier filtración.

¿Cuánto tiempo le sirve una credencial filtrada al atacante? (escala ilustrativa)



Clave de largo plazo

Sirve hasta que alguien la rote o la borre: semanas o meses



Credencial temporal

Hasta 1 hora

Caduca sola: aunque la roben, deja de servir



Claves de largo plazo

- Viven en archivos, scripts y repositorios
- Hay que rotarlas a mano
- Una filtración dura hasta que alguien la detecta

Credenciales temporales

- Se piden al asumir un rol o iniciar sesión federada
- Se renuevan solas
- Ventana de ataque mínima y trazable

Fuente: modelo ilustrativo propio; conceptos de AWS IAM User Guide (Security best practices)

SEMANA 2 · MODELOS DE DESPLIEGUE E IDENTIDAD Y ACCESO

Roles, políticas y federación

Parte 3 de 3 · Unidad 1

Ing. Rodolfo Cañas Cervantes

Universidad de la Costa (CUC) · Ingeniería de Sistemas

Semana 2 · Periodo 2026-2 · Barranquilla, Colombia

Roles sin claves, federación con directorios, anatomía de una política y lógica de evaluación

Roles para aplicaciones: cero claves en el código

Un perfil de instancia entrega credenciales temporales a la máquina.

MAL: claves dentro del código

Repositorio

```
config.py
AWS_KEY = "AKIA...."
AWS_SECRET = "9fX..."
```

Cualquiera con acceso al repositorio ve la clave

se copia, se publica, se filtra

Servidor → usa la clave fija → Datos

Riesgo: la clave vive meses, la ve mucha gente,
y nadie sabe quién la usó

BIEN: un rol para la máquina

Servidor EC2 + Rol del servidor

Perfil de instancia
asocia el rol a la máquina al crearla

Servicio de metadatos
169.254.169.254

Credenciales temporales y renovadas solas

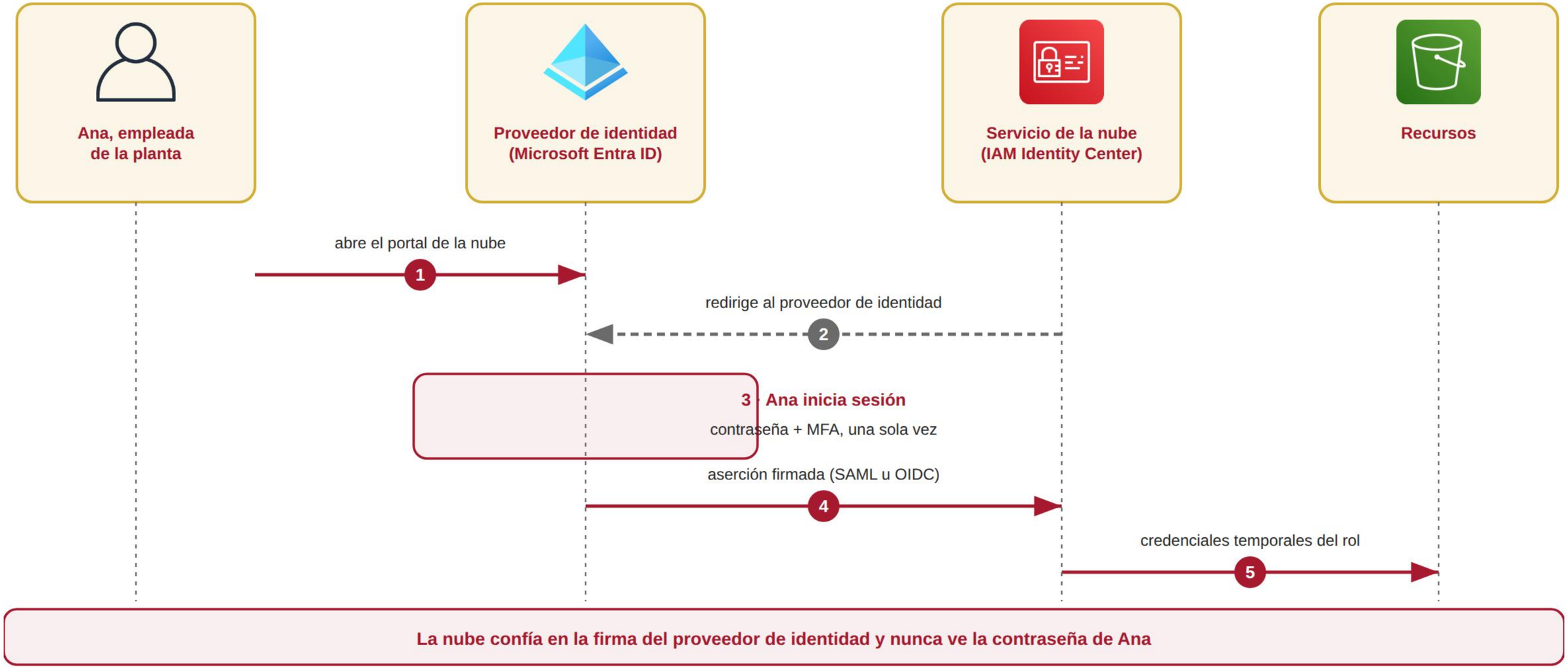
Datos

Sin claves en el código: nada que filtrar
y cada acceso queda registrado en CloudTrail

Fuente: adaptado de AWS IAM User Guide (IAM roles for Amazon EC2) — íconos AWS Architecture Icons

Federación: una sola identidad, muchas nubes

La nube confía en un proveedor de identidad y no guarda contraseñas.



Fuente: adaptado de AWS IAM Identity Center y Microsoft Entra ID (SAML y OpenID Connect)

Directorio de la planta, acceso único para la nube

Se sincroniza el directorio existente para que una cuenta sirva en todas partes.



Fuente: adaptado de Microsoft Entra Connect y Azure Architecture Center (CC BY 4.0) — íconos Azure y AWS

Ciclo de vida: ingreso, cambio y salida

Las identidades se crean, se ajustan y se retiran con un proceso, no a mano.



Alta

1. Se crea la identidad desde Recursos Humanos
2. Entra al grupo según su cargo
3. MFA obligatorio desde el primer día

Traslado

1. Se actualizan sus grupos
2. Se retiran los accesos del cargo anterior
3. Se revisan permisos acumulados

Baja

1. Se desactiva en minutos, no en días
2. Se cierran sesiones y claves
3. Se revisan recursos que creó

Revisión periódica de accesos

Cada trimestre, el dueño de cada sistema confirma quién conserva acceso. Los contratistas externos reciben una fecha de vencimiento (por ejemplo 90 días) y deben renovarse expresamente.

Herramientas: revisiones de acceso del directorio y IAM Access Analyzer en AWS



Access Analyzer

Fuente: adaptado de Microsoft Entra ID Governance y AWS Well-Architected (Security: Identity management)

CIERRE

Lo que queda de la Parte 3

La identidad de CIC: directorio único, MFA, roles temporales y raíz blindada.



Tres ideas para llevar

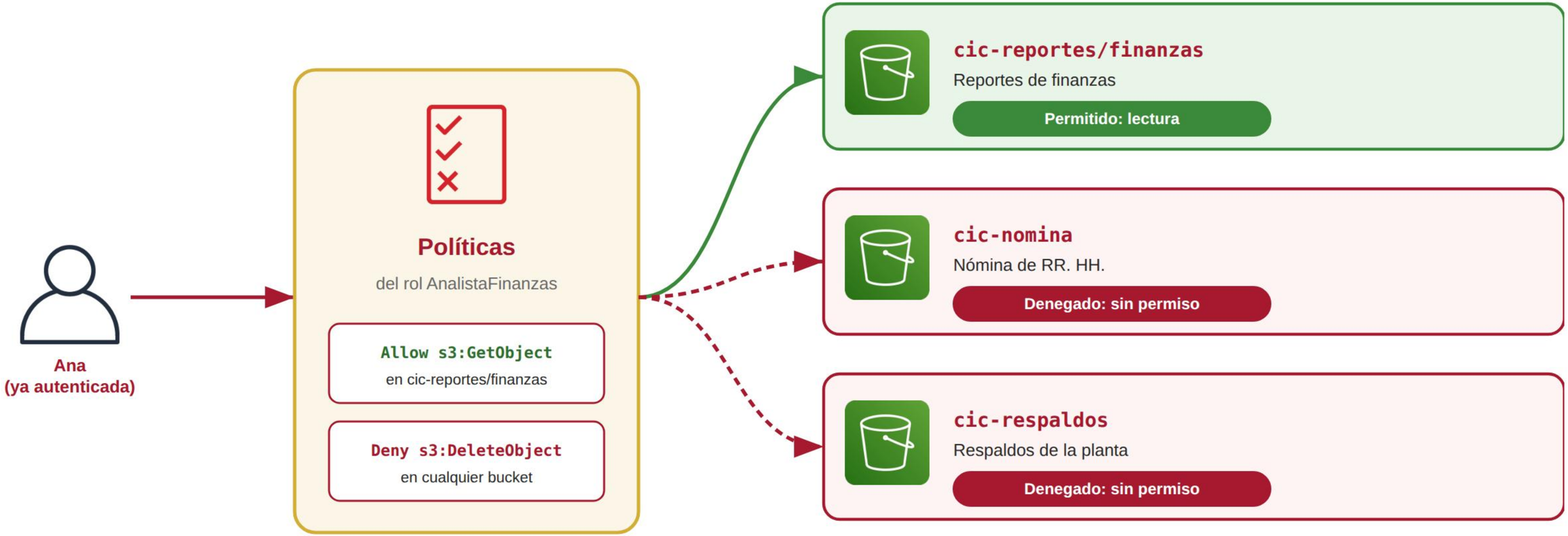
- **Autenticar primero, autorizar después**
- **Raíz blindada, usuarios con MFA y roles temporales**
- **La federación centraliza altas y bajas**

Siguiente: las políticas que dicen exactamente qué puede hacer cada identidad

Fuente: elaboración propia a partir de AWS IAM y Microsoft Entra ID — caso docente CIC

Ana ya entró: ¿qué puede tocar?

La identidad abre la puerta; las políticas deciden qué hay detrás de cada una.



Estar autenticado no abre todas las puertas: cada acción se compara con las políticas

Esa comparación es lo que estudiamos en esta parte

Fuente: caso docente CIC; conceptos de AWS IAM User Guide (Policies and permissions) — íconos AWS Architecture Icons

Dos tipos de política y los límites que las recortan

Una se pega a la identidad; otra, al recurso; los límites siempre reducen.

Política basada en identidad

"Esta identidad puede hacer esto"



Viaja con la persona o el rol

Política basada en recurso

"Este recurso admite a estos"



Vive pegada al recurso, incluso para otra cuenta

Además existen límites que recortan lo que las políticas otorgan (Semana 9)

Límites de la organización (SCP)

Límite de permisos del rol

Permisos efectivos

solo lo que TODAS las capas permiten

Fuente: adaptado de AWS IAM User Guide (Policy types) — íconos AWS Architecture Icons

Anatomía de una política JSON

Cuatro elementos esenciales: efecto, acción, recurso y condición.

```
{
  "Version": "2012-10-17",
  "Statement": [{
    "Sid": "LeerReportesFinanzas",
    "Effect": "Allow",
    "Action": ["s3:GetObject", "s3:ListBucket"],
    "Resource": [
      "arn:aws:s3:::cic-reportes",
      "arn:aws:s3:::cic-reportes/finanzas/*"
    ],
    "Condition": {
      "Bool": {"aws:MultiFactorAuthPresent": "true"}
    }
  }]
}
```



Effect

Allow o Deny: ¿se permite o se niega?

Action

Qué operaciones: leer objetos y listar el bucket

Resource

Sobre qué: dos ARN exactos, no un asterisco

Condition

Cuándo: solo si hay MFA en la sesión

Sid = nombre opcional de la regla · Version = versión del lenguaje (no la fecha de hoy)

Fuente: adaptado de AWS IAM User Guide (Policies and permissions, JSON policy elements reference)

Effect y Action: permisos exactos o comodines

Mientras más amplio el comodín, mayor el daño posible si la identidad se compromete.

Qué tan amplia es la acción: del permiso exacto al comodín

`s3:GetObject`
Una sola acción: leer objetos
Exacta

`s3:Get*`
Todas las acciones de lectura de S3
Acotada

`s3:*`
Todas las acciones de S3, incluida borrar
Amplia

`*:*`
Todas las acciones de todos los servicios
Administrador total

Effect: Allow

Concede el permiso si ninguna regla lo niega.
Por defecto, todo lo que no se permite está negado.

Effect: Deny

Niega siempre, aunque otra regla permita.
Se usa para barreras que nadie debe cruzar.

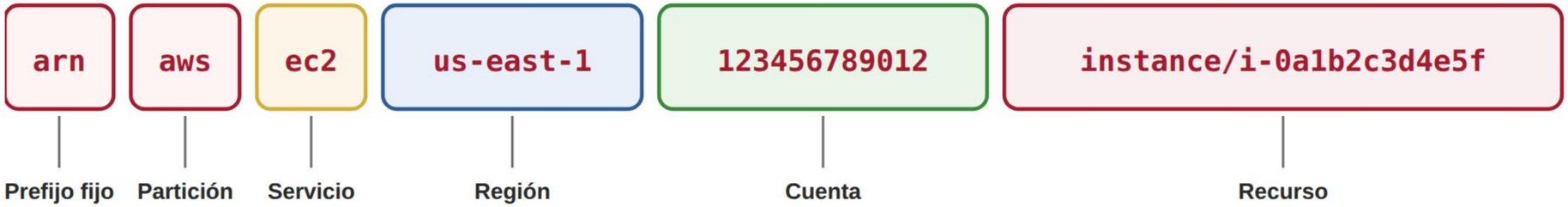


Fuente: adaptado de AWS IAM User Guide (Policy elements: Action, Effect) y AWS Well-Architected (Security)

Resource: el ARN identifica el recurso exacto

Cuanto más específico el ARN, menor la superficie de ataque.

Anatomía de un ARN (Amazon Resource Name)



Ejemplo de una instancia EC2. En S3 la región y la cuenta van vacías: arn:aws:s3:::cic-reportes

Qué tan amplio es el Resource

`arn:aws:s3:::cic-reportes/finanzas/2026/*`
Solo los reportes de finanzas de este año

`arn:aws:s3:::cic-reportes/finanzas/*`
Toda la carpeta de finanzas

`arn:aws:s3:::cic-reportes/*`
Todos los objetos del bucket

`*`
Cualquier recurso de la cuenta

Fuente: adaptado de AWS IAM User Guide (ARNs) — cuenta 123456789012 de documentación

Condition: el permiso solo vale en ciertas circunstancias

Todas las condiciones de una regla deben cumplirse a la vez.

Contexto de la solicitud



Quién
Ana, rol AnalistaFinanzas

Desde dónde
203.0.113.25 (red de la planta)

MFA
sesión autenticada con MFA

Región
us-east-1

Hora
jueves, 10:15

`aws:MultiFactorAuthPresent`
`= true`
La sesión debe tener MFA

✔

`aws:SourceIp`
`dentro de 203.0.113.0/24`
Solo desde la red de la planta

✔

`aws:RequestedRegion`
`= us-east-1`
Solo en la región autorizada

✔

Todas se cumplen
la regla Allow aplica

¿Y si una condición falla?

Ana sin MFA, o fuera de la planta

La condición es falsa: la regla Allow no aplica.
No hay otra regla que permita, entonces el resultado es denegado implícito.

Para qué sirven en CIC

- Exigir MFA en acciones sensibles
- Restringir por IP a la planta o a la VPN
- Limitar regiones y etiquetas de recurso

Fuente: adaptado de AWS IAM User Guide (Condition keys) — IP 203.0.113.0/24 de documentación

Lógica de evaluación: el Deny siempre gana

Primero se busca un Deny; luego un Allow; si no hay ninguno, se niega.

Solicitud
llega a la API

¿Alguna política lo niega de forma explícita (Deny)?

Sí → **DENEGADO**
Deny explícito: gana siempre

No → **¿Alguna política lo permite (Allow)?**

Sí → **PERMITIDO**
Hay Allow y ningún Deny

No → **DENEGADO**
Deny implícito: nada lo permitió



Orden de prioridad

Deny explícito > Allow > Deny implícito

Fuente: adaptado de AWS IAM User Guide (Policy evaluation logic)

PRÁCTICA

Ejercicio: resuelve tres solicitudes

Aplica el orden Deny explícito, Allow, Deny implícito a cada caso.

Políticas del rol de Ana

A **Effect: Allow**

`Action: s3:*`

Resource: cic-reportes y su contenido

B **Effect: Deny**

`Action: s3:DeleteObject`

Resource: todos los buckets

C **Sin regla para cic-nomina**

ni Allow ni Deny

1 **Leer un reporte de cic-reportes**

`s3:GetObject`

A permite · ningún Deny aplica



PERMITIDO

2 **Borrar un reporte de cic-reportes**

`s3:DeleteObject`

A permite, pero B niega de forma explícita

DENEGADO
(explícito)

3 **Leer un archivo de cic-nomina**

`s3:GetObject`

Ninguna regla lo permite

DENEGADO
(implícito)

Fuente: ejercicio propio basado en AWS IAM User Guide (Policy evaluation logic)

Mínimo privilegio: cerrar la brecha

Cuanto más permiso sobra, más daño puede causar un error o una cuenta robada.

Permisos concedidos contra permisos realmente usados (ilustrativo)



Mínimo privilegio

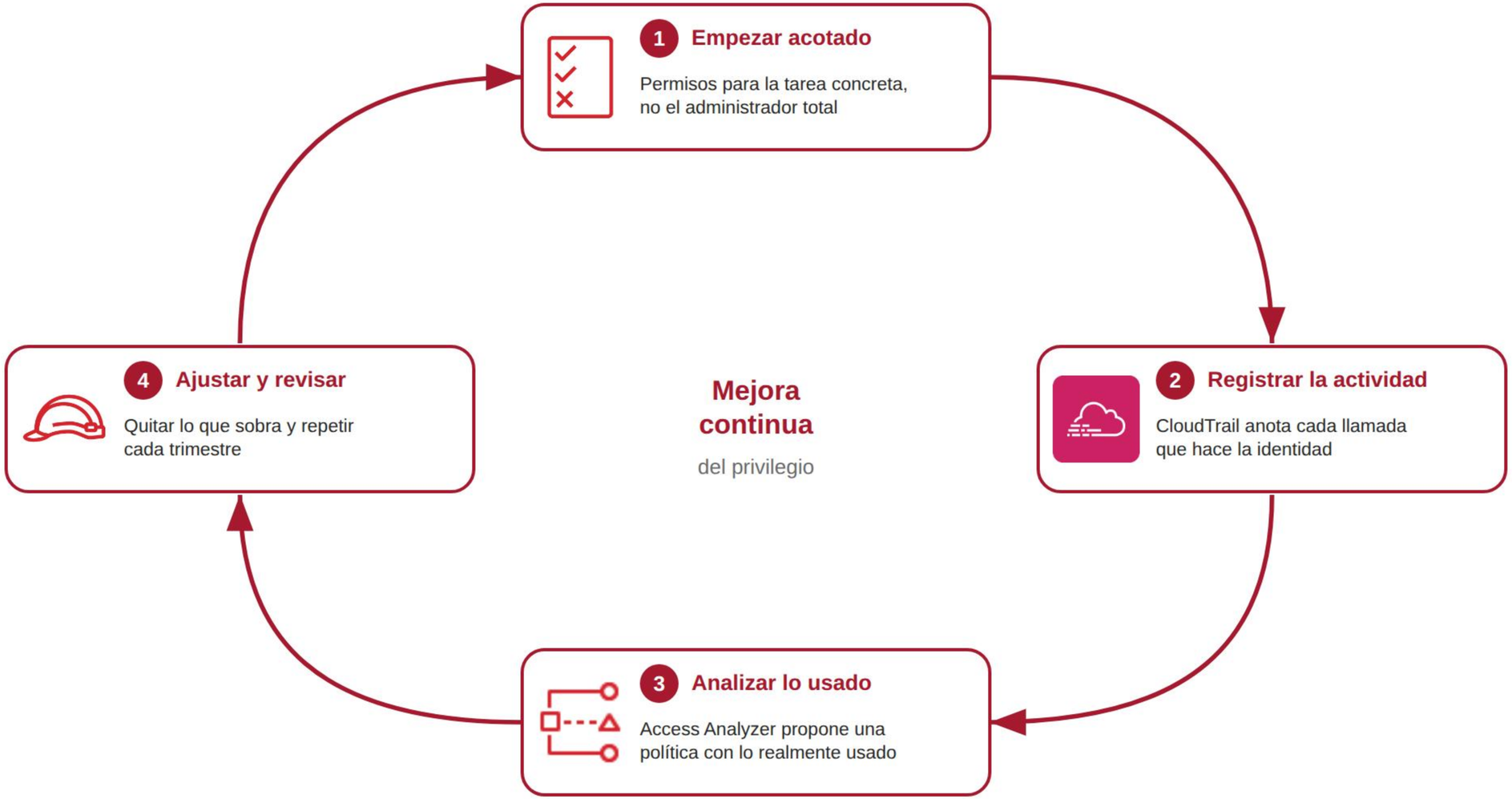
Cada identidad recibe solo los permisos necesarios, sobre los recursos necesarios, durante el tiempo necesario.

La brecha de privilegio es el espacio que un atacante (o un error) puede aprovechar.

Fuente: modelo ilustrativo propio; concepto de AWS Well-Architected (SEC03 Permissions management)

El camino al mínimo privilegio es un ciclo

Se empieza acotado, se observa qué se usa y se recorta de forma periódica.



En la práctica

1. Roles, no usuarios con claves
2. Sin asterisco en Action ni Resource
3. Condiciones: MFA, IP y región
4. Revisión de accesos cada trimestre
5. Eliminar lo que nadie usa

Fuente: adaptado de AWS IAM Access Analyzer (policy generation) y AWS Well-Architected (Security)

RBAC con ámbitos: quién, qué rol y dónde

Un rol asignado en un ámbito se hereda por todo lo que contiene.



Un permiso asignado arriba se hereda hacia abajo

Asignación de rol = tres piezas

Quién	Qué rol	Dónde
usuario, grupo o identidad de aplicación	Lector, Colaborador o Propietario	el ámbito donde aplica

Quién + Qué rol + Dónde

Ejemplo 1

Grupo Auditores + Lector + Suscripción Producción

ve todo, no cambia nada

Ejemplo 2

Equipo Tienda + Colaborador + rg-tienda

crea y modifica solo ahí

Fuente: adaptado de Microsoft Learn: Azure RBAC y ámbitos (CC BY 4.0) — íconos Azure

Roles integrados: de Lector a Propietario

Cada rol añade capacidades; en AWS, las etiquetas permiten una lógica parecida.

Roles integrados de Azure: qué puede hacer cada uno

	Ver recursos	Crear y modificar	Asignar acceso
Lector `Reader`	✔	—	—
Colaborador `Contributor`	✔	✔	—
Administrador de acceso `User Access Administrator`	✔	—	✔
Propietario `Owner`	✔	✔	✔

Más poder, más riesgo



En AWS, la misma idea con etiquetas (ABAC)

`Ana · etiqueta Area=finanzas` (identidad) = `Bucket · etiqueta Area=finanzas` (recurso) → **Acceso permitido**

Una sola política sirve para todas las áreas: el acceso sigue la etiqueta

Fuente: adaptado de Microsoft Learn (Azure built-in roles) y AWS IAM User Guide (ABAC) — CC BY 4.0

CASO INTEGRADOR

Caso CIC: quién puede qué sobre qué

Roles por función, permisos exactos y barreras globales de negación.

	Reportes financieros	ERP y nómina	Sensores de planta	Tienda B2B	Registros de auditoría
Finanzas	Escribir	Escribir	sin acceso	sin acceso	Leer
Planta	sin acceso	sin acceso	Escribir	sin acceso	sin acceso
Desarrollo	sin acceso	sin acceso	Leer	Administrar	Leer
Auditoría externa	Leer	Leer	Leer	Leer	Leer
App tienda (rol)	sin acceso	Leer	sin acceso	Escribir	sin acceso

Barreras para todos (Deny): nadie borra los registros · nadie desactiva CloudTrail · nada fuera de la región autorizada

Más: MFA obligatorio para escribir en el ERP · acceso a sensores solo desde la red de la planta · auditoría con duración limitada

Cada celda es una política corta con acciones exactas, ARN específicos y condiciones.

Fuente: caso docente Corporación Industrial del Caribe; conceptos de AWS Well-Architected (SEC03)

CIERRE DE LA SEMANA

Semana 2 en cuatro ideas

Y un adelanto: la Semana 3 guarda datos en objetos, bloques y archivos.

1 El modelo se elige por carga



Pública, privada, comunitaria, híbrida y multi-nube según control, costo y soberanía

2 Una nube privada se construye por servicios



OpenStack, enlaces VPN o dedicados y un plan contra el lock-in

3 La identidad es el nuevo perímetro



MFA, raíz blindada, roles temporales y federación

4 Las políticas definen el acceso exacto



Deny explícito, Allow, Deny implícito; mínimo privilegio y ámbitos

Próxima semana: Almacenamiento en la nube



Objetos

S3: archivos y sitios estáticos



Bloques

EBS: el disco de la VM



Archivos

EFS: carpetas compartidas

Laboratorio evaluado

Sitio web estático en S3

AWS Academy · 10 por ciento

Aplica las políticas de hoy

Fuente: elaboración propia — calendario del curso (index.html)